

Recon and Enumeration of a Vulnerable Host

Objective

The objective for this project is to simulate a reconnaissance and enumeration exercise on an intentionally vulnerable virtual machine, scanning for potential vulnerabilities on the network, the consequences it presents and outline methods to mitigate against specific threats. This project highlights the early stages of penetration testing and cyber security risk analysts, emphasising the importance of collecting information and investigating deeper into the data discovered.

This project follows select stages of the Penetration Testing Execution Standard (PTES) framework, which fits the objective of this project. This includes intelligence gathering, vulnerability analysis and reporting, excluding exploitation as it does not fit the scope of this project.

Background

For ethical hackers, it is important they gain knowledge about the system they are attempting to gain access to, in order to assess the weaknesses of an organisation's systems. In conjunction with risk auditors, the outcome of a thorough assessment of an organisation's systems should lead to stronger security measures in place and a greater understanding of the risks these vulnerabilities can present to an organisation, across the CEOs, employees and clients. CEOs must ensure their organisation is complying with laws such as the General Data Protection Regulation (GDPR), as they place heavy emphasis on organisations to comply with the legislations set and correctly handle their customers' data. This is so companies can avoid financial loss, reputational damage and business downtime. Clients must feel they can trust the businesses they encounter with their personal data. This project should demonstrate to the reader of how significant risk management is across organisations, but inclusively home networks as people utilise the services mentioned.

Tools Used

- **VirtualBox** – To launch virtual machines
- **Metasploitable 2** – Target machine that will be analysed
- **Kali Linux** – Attacker machine
- **Nmap** – Network analyser tool
- **Netcat** – Test connectivity and interaction with services
- **Enum4Linux** – Command line tool enumerating SMB services
- **Smbclient** – Connecting to SMB server
- **Nikto** – Website vulnerability scanner

Prerequisites

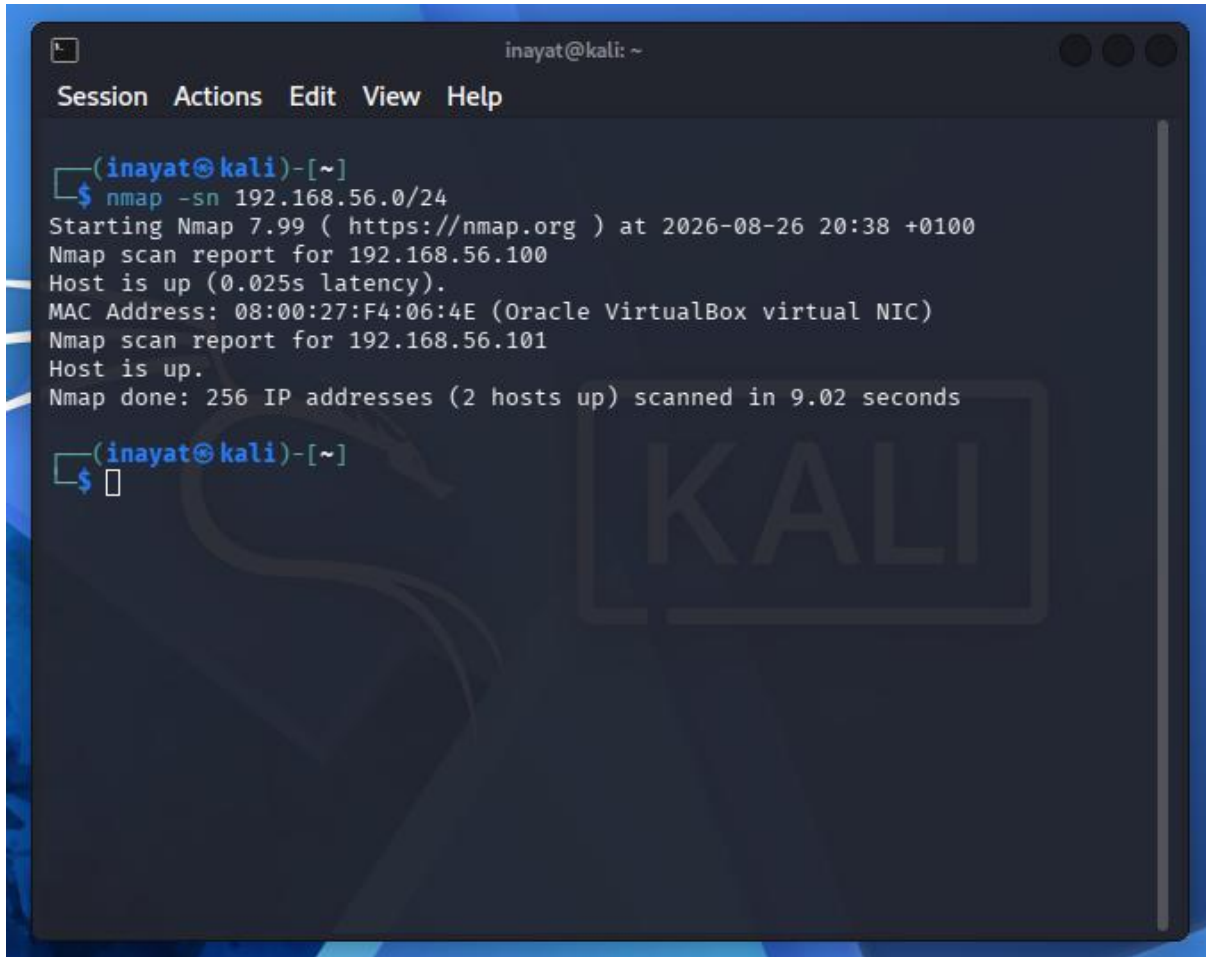
- It is illegal to capture network traffic of a network you have no permission to scan for. During this project, tasks will be conducted within an isolated and controlled environment to prevent infractions with the law.
- Kali Linux and Metasploitable will both be using internal network adapters, ensuring Kali Linux is only scanning the Metasploitable machine without interfering with external networks.
- This project solely focuses on reconnaissance and enumeration of Metasploitable; no exploits will be executed.

Prior to conducting the task, it is important to understand the system that is being targeted. In this instance, Metasploitable 2 is used, an intentionally vulnerable virtual machine made to be tested, exploited and assessed in a controlled environment without breaching ethical and legal boundaries.

Reconnaissance

To use Nmap, an IP address of the target host is required. On Kali Linux, the command `nmap -sn 192.168.56.0/24` will be executed:

- `-sn` flag checks for hosts that are online without completing a port scan
- `/24` scans for all the available devices within a total of 256 IP addresses.



```
inayat@kali: ~  
Session Actions Edit View Help  
  
(inayat@kali)-[~]  
$ nmap -sn 192.168.56.0/24  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-26 20:38 +0100  
Nmap scan report for 192.168.56.100  
Host is up (0.025s latency).  
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)  
Nmap scan report for 192.168.56.101  
Host is up.  
Nmap done: 256 IP addresses (2 hosts up) scanned in 9.02 seconds  
  
(inayat@kali)-[~]  
$
```

Kali's IP address is 192.168.56.101, meaning Metasploitable's IP address is 192.168.56.102 as both machines are using an internal adapter which connects them together.

Service Versions of Open Ports

After identifying the target IP address, using `nmap -sV 192.168.56.102` lists all the open ports and their service versions. This provides information of the services which can then be enumerated further to discover potential exploits that may be applicable to the target.

```
(inayat@kali)-[~]
$ nmap -sV 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 21:10 +0100
Nmap scan report for 192.168.56.102
Host is up (0.045s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        Netkit rshd
514/tcp   open  shell        GNU Classpath grmiregistry
1099/tcp  open  bindshell    Metasploitable root shell
1524/tcp  open  nfs          2-4 (RPC #100003)
2049/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.41 seconds
```

- 23 ports are open
- 2 of the ports' service versions are unknown (port 513 and 6000)

Identifying the Operating System (OS)

Identifying the OS of a machine is important to understand the vulnerabilities and exploit capabilities that are specifically designed to target that system. Using nmap -O 192.168.56.102 will present the OS the target system is running on.

```
(inayat@kali)-[~]
$ nmap -O 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 21:42 +0100
Nmap scan report for 192.168.56.102
Host is up (0.021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

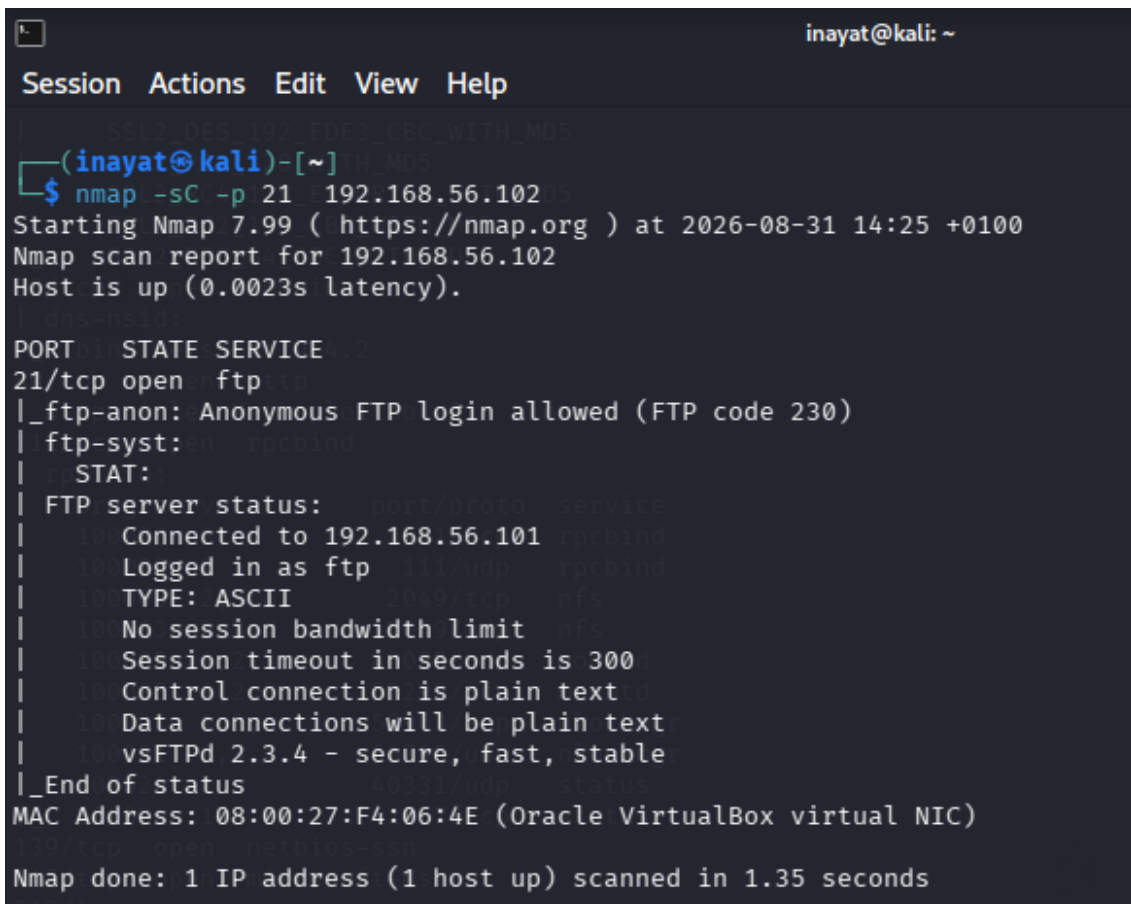
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 3.57 seconds
```

The target is running a Linux 2.6 operating system.

Service Specific Enumeration

For further inspection towards specific ports and services to assess their configurations, using -sC will execute a default set of scripts to scan ports and services. This is performed using the Nmap Scripting Engine to promptly execute a variety of scripts. Following the -sC flag, a -p flag can be used to specify the port to enumerate.

Port 21 – FTP



```
inayat@kali: ~  
Session Actions Edit View Help  
[inayat@kali]-[~]TH_MD5  
$ nmap -sC -p 21 192.168.56.102  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-31 14:25 +0100  
Nmap scan report for 192.168.56.102  
Host is up (0.0023s latency).  
PORT      STATE SERVICE  
21/tcp    open  ftp  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-syst: en  rpcbind  
|_STAT:  
| FTP server status:  port/proto  service  
| 100 Connected to 192.168.56.101  rpcbind  
| 100 Logged in as ftp  111/udp  rpcbind  
| 100 TYPE: ASCII  2049/tcp  nfs  
| 100 No session bandwidth limit  nfs  
| 100 Session timeout in seconds is 300  
| 100 Control connection is plain text  
| 100 Data connections will be plain text  
| 100 vsFTPD 2.3.4 - secure, fast, stable  
|_End of status  
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)  
Nmap done: 1 IP address (1 host up) scanned in 1.35 seconds
```

- Version: vsFTPD 2.3.4
- Allows for anonymous FTP login – no credentials are needed to access the FTP server
- Data and control connections are sent in plain text – sensitive information can be captured due to a lack of encryption

Port 22 – SSH

```
(inayat@kali)-[~]
$ nmap -sC -p 22 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 14:24 +0100
Nmap scan report for 192.168.56.102
Host is up (0.0020s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.96 seconds
```

- Version: OpenSSH 4.7p1
- Secure Shell to allow remote access to computers
- Implements encryption – Data is kept secure from interceptors
- Includes SFTP client and server support
- Utilises Trust on First Use (TOFU) – Saves a digital fingerprint key of the server on the user's device to verify the integrity of the server for future connections. Helps to mitigate against Man-in-the-Middle attacks as future connections are kept secure between the device and server.

To establish a remote connection to the SSH service between Kali Linux and Metasploitable, the command `ssh -oHostKeyAlgorithms=+ssh-rsa msfadmin@192.168.56.102` must be entered. This is because modern OpenSSH clients like Kali Linux have disabled ssh-rsa host key algorithms. This means legacy key algorithms are needed to access systems that utilise the outdated SSH service.

```
(inayat@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa msfadmin@192.168.56.102
The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? 
```

Port 23 – Telnet

```
inayat@kali: ~  
Session Actions Edit View Help  
(inayat@kali)-[~]  
$ nmap -sC -p 23 192.168.56.102  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 11:09 +0100  
Nmap scan report for 192.168.56.102  
Host is up (0.0067s latency).  
  
PORT      STATE SERVICE  
23/tcp    open  telnet  
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 8.23 seconds
```

- Version: Linux telnetd
- Telnet allows the user running the service to communicate with remote computers over TCP/IP
- Transmits data in plaintext
- Replaced by SSH as a more secure version which encrypts data for transfer.

Port 25 – SMTP

```
(inayat@kali)-[~]
└─$ nmap -sC -p 25 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 13:23 +0100
Nmap scan report for 192.168.56.102
Host is up (0.0043s latency).
Not recognized option '--script-vuln'
Run 'nmap -h' for a summary of options.

PORT      STATE SERVICE
25/tcp    open  smtp
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STAR
TTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-09-02T18:30:34+00:00; -17h52m31s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateO
rProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Host script results:
|_clock-skew: -17h52m31s

Nmap done: 1 IP address (1 host up) scanned in 2.69 seconds
```

- Version: Postfix smtpd
- Simple Mail Transfer Protocol – Sending mail from an email client to the email server over the internet and is prepared to be delivered.
- Supports SSLv2 - Deprecated in 2011 and is now replaced with TLS
- The SSL certificate has expired on 2010-04-16, which the certificate was valid from 2010-03-17. The certificate was valid for 1 month.
- SMTP service also supports TLS (Transport Layer Security) protocol.

Netcat Enumeration

```
(inayat@kali)-[~]
└─$ nc 192.168.56.102 25
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
VRFY root
252 2.0.0 root
VRFY msfadmin
252 2.0.0 msfadmin
VRFY madeupusername
550 5.1.1 <madeupusername>: Recipient address rejected: User unknown in local recipient
table
```

The observations made were to test the SMTP server's response to user mailboxes that exist on the host, which were queried using the 'VRFY' command:

- '252 2.0.0 root' and '252 2.0.0 msfadmin' – The server could not confirm if the user's (root) mailbox exist but still accepts the name.
- 'madeupusername' was a test to see if the SMTP service would respond the same exact way, it is instead rejected as the user is unknown to the server.

Port 53 - DNS

```
(inayat@kali)-[~]
$ nmap -sC -p 53 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 19:01 +0100
Nmap scan report for 192.168.56.102
Host is up (0.030s latency).

PORT      STATE SERVICE
53/tcp    open  domain
| dns-nsid:
|_ bind.version: 9.4.2
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)
```

- Version: ISC BIND 9.4.2
- Domain Name System (DNS) – Converts website names into IP addresses to allow users to connect to websites
- Internet Systems Consortium (ISC) – An organisation that develops and maintains important open-source internet software, such as BIND.
- Berkeley Internet Name Domain (BIND) – Commonly adopted DNS service across operating systems.

DNS enumeration

```
(inayat@kali)-[~]
$ dig @192.168.56.102
; <<>> DiG 9.20.23-1-Debian <<>> @192.168.56.102
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: SERVFAIL, id: 31203
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1
;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;      IN      NS
;; Query time: 1979 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Sat Sep 05 02:11:12 BST 2026
;; MSG SIZE rcvd: 28
```

Using the dig command line tool to enumerate the DNS server on Metasploitable, it returned the status 'SERVFAIL'. This response from the server happens when a 5DNS resolver is unable to obtain a response from the authoritative name server. This could be due to misconfigured DNS records or servers, preventing connection.

Port 80 – HTTP

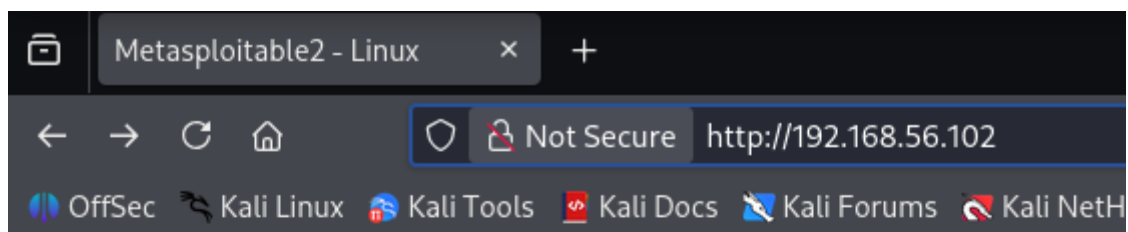
```
(inayat@kali)-[~]
$ nmap -sC -p 80 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-17 17:36 +0100
Nmap scan report for 192.168.56.102
Host is up (0.0027s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-title: Metasploitable2 - Linux
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.02 seconds
```

- Version: Apache httpd 2.2.8
- Hypertext Transfer Protocol (HTTP) – Allows users to access websites over the internet
- Accessing the HTTP protocol for Metasploitable presents a website with its login credentials (as seen in Telnet) and a variety of other publicly known vulnerable websites.

Accessing the Metasploitable website



Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

Enumerating HTTP

```
(inayat@kali)-[~]
└─$ nmap --script=http-enum -p 80 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-17 18:50 +0100
Nmap scan report for 192.168.56.102
Host is up (0.026s latency).
PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
| /tikiwiki/: Tikiwiki
| /test/: Test page
| /phpinfo.php: Possible information file
| /phpMyAdmin/: phpMyAdmin
| /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
| /icons/: Potentially interesting folder w/ directory listing
|_ /index/: Potentially interesting folder
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)
```

Using the Nmap script 'http-enum' will enumerate the web service by sending HTTP requests to the service and checking against a database of HTTP fingerprints, to identify directories, common and hidden file and folder names and web applications that exist.

- /tikiwiki/ - Presents an installation page for TikiWiki, a content management platform used to build websites written in PHP. Accessing it shows a database connection error whilst connecting using the root account
- /test/ - Presents a directory listing containing a single folder titled 'testoutput/'.
- /phpinfo.php – An information page from the programming language PHP that contains data such as the web server, security settings, server configuration settings and the PHP version.
- /phpMyAdmin – A database management tool which manages MySQL and MariaDB databases.
- /doc/ and /icons/ - These directories have directory listing enabled. Contains application files such as Filezilla and Firefox and images. 'Dav/2' on the /doc/ line suggests WebDAV is enabled, a HTTP extension which adds methods such as PUT and DELETE, alongside read-only methods such as GET and POST.
- /index/ – Displays the homepage.

http-methods

Running the 'http-methods' Nmap script lists the requests that a user can make to the web server.

```
(inayat@kali)-[~]
$ nmap --script=http-methods -p 80 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-17 19:59 +0100
Nmap scan report for 192.168.56.102
Host is up (0.028s latency).

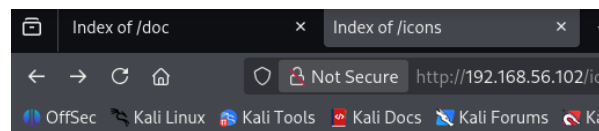
PORT      STATE SERVICE
80/tcp    open  http
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.22 seconds
```

- GET – Requests information about the resource from the server. Read-only data, no changes can be made.
- HEAD – Requests HTTP response headers from the web server without the body of text.
- POST – Sends data from the client to the web server. Request the server to process data input.
- OPTIONS – Requests the methods that are supported for a resource.

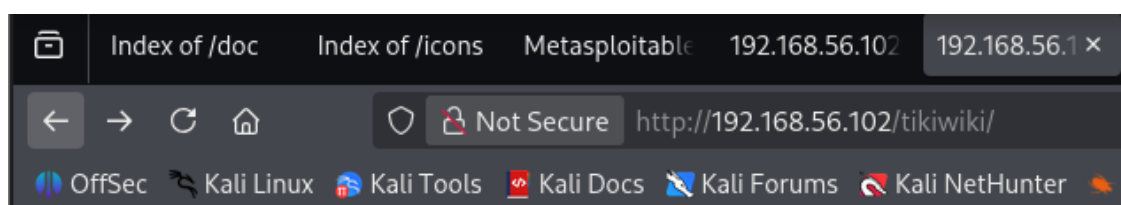
Methods such as PUT and DELETE are not present. PUT allows the user to create and upload files on the web server. DELETE allows users to delete files and resources on a web server.

Index of /icons		
←	→	↻
Not Secure http://192.168.56.102/doc/		
OffSec	Kali Linux	Kali Tools
Kali Docs	Kali Forums	Kali NetHu
e2fsprogs/	16-Mar-2010 18:58	-
ecj-gcj/	23-Mar-2010 17:54	-
ecj/	23-Mar-2010 17:54	-
ed/	16-Mar-2010 19:11	-
eject/	16-Mar-2010 19:00	-
esound-common/	20-May-2012 15:07	-
etern/	20-May-2012 14:47	-
ethtool/	16-Mar-2010 19:00	-
fakeroot/	28-Apr-2010 00:06	-
fastjar/	23-Mar-2010 17:54	-
fdutils/	16-Mar-2010 19:11	-
figlet/	20-May-2012 15:05	-
file/	16-Mar-2010 19:11	-
filezilla-common/	20-May-2012 15:07	-
filezilla/	20-May-2012 15:07	-
findutils/	16-Mar-2010 18:58	-
firefox-3.0/	20-May-2012 15:07	-
firefox-branding/	20-May-2012 15:07	-
firefox/	20-May-2012 15:07	-
fluxbox/	20-May-2012 14:44	-
fontconfig-config/	23-Mar-2010 17:54	-
fontconfig/	23-Mar-2010 17:54	-
friendly-recovery/	16-Mar-2010 19:11	-
ftp/	16-Mar-2010 19:11	-
fuse-utils/	16-Mar-2010 19:11	-
g++-4.2/	19-Apr-2010 20:59	-
g++/	17-Apr-2010 14:12	-
gapplotviewer-4.2/	23-Mar-2010 17:54	-
gcc-4.2-base/	19-Apr-2010 20:59	-



Index of /icons

Name	Last modified	Size	Description
Parent Directory	-	-	-
README	28-Aug-2007 06:48	5.0K	-
README.html	28-Aug-2007 06:48	35K	-
a.gif	20-Nov-2004 15:16	246	-
a.png	28-Aug-2007 06:54	317	-
alert.black.gif	20-Nov-2004 15:16	242	-
alert.black.png	28-Aug-2007 06:54	304	-
alert.red.gif	20-Nov-2004 15:16	247	-
alert.red.png	28-Aug-2007 06:54	315	-
apache_pb.gif	20-Nov-2004 15:16	2.3K	-
apache_pb.png	28-Aug-2007 06:54	2.0K	-
apache_pb2.gif	20-Nov-2004 15:16	2.4K	-
apache_pb2.png	28-Aug-2007 06:54	2.1K	-
apache_pb2_ani.gif	20-Nov-2004 15:16	2.1K	-
back.gif	20-Nov-2004 15:16	216	-
back.png	28-Aug-2007 06:54	316	-
ball.gray.gif	20-Nov-2004 15:16	233	-
ball.gray.png	28-Aug-2007 06:54	317	-
ball.red.gif	20-Nov-2004 15:16	205	-
ball.red.png	28-Aug-2007 06:54	295	-
binary.gif	20-Nov-2004 15:16	246	-
binary.png	28-Aug-2007 06:54	316	-
binhex.gif	20-Nov-2004 15:16	246	-
binhex.png	28-Aug-2007 06:54	325	-
blank.gif	20-Nov-2004 15:16	148	-



TikiWiki is not properly set up:

Unable to connect to the database !

[Go here to begin the installation process](#), if you haven't done so already.

Access denied for user 'root'@'localhost' (using password: YES)

Port 139/445 – SMB

```
(inayat@kali)-[~]
$ nmap -sV -sC -p 139,445 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 18:32 +0100
Nmap scan report for 192.168.56.102
Host is up (0.022s latency).

PORT      STATE SERVICE      VERSION
139/tcp    open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-09-17T15:18:19-04:00
|_clock-skew: mean: -2d20h14m16s, deviation: 2h49m42s, median: -2d22h14m16s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
```

- Version: Samba smbd 3.0.20-Debian (445), Samba smbd 3.X – 4.X (139)
- Server Message Block (SMB) – A network communication protocol which allows users to share access and use resources such as files and devices like printers on a network.
- Samba – A software suite which implements SMB to connect Linux and Unix systems with Windows clients to share files and devices.
- Port 139 – SMB over NetBIOS
- Port 445 – SMB directly over TCP
- Challenge_response: supported – The service supports challenge-response authentication procedures to verify a user to grant them access.
- Message_signing: disabled (dangerous, but default) – Messages between the client and server are not signed.

smbclient

```
inayat@kali: ~  
Session Actions Edit View Help  
(inayat@kali)-[~]  
$ smbclient -L //192.168.56.102  
Password for [WORKGROUP\inayat]:  
Anonymous login successful  


| Sharename | Type | Comment                                                   |
|-----------|------|-----------------------------------------------------------|
| print\$   | Disk | Printer Drivers                                           |
| tmp       | Disk | oh noes!                                                  |
| opt       | Disk |                                                           |
| IPC\$     | IPC  | IPC Service (metasploitable server (Samba 3.0.20-Debian)) |
| ADMIN\$   | IPC  | IPC Service (metasploitable server (Samba 3.0.20-Debian)) |

  
Reconnecting with SMB1 for workgroup listing.  
Anonymous login successful  


| Server    | Comment        |
|-----------|----------------|
| Workgroup | Master         |
| WORKGROUP | METASPLOITABLE |


```

Using the command line tool smbclient to connect to the SMB server. The command 'smbclient -L' lists the shares available on the server with comments attached to the shares.

- The service permits anonymous login as noted by the screenshot stating, 'Anonymous login successful'
- Shares available: print\$, tmp, opt, IPC\$, ADMIN\$
- Notably, tmp has a comment attached stating 'oh noes!'

Smb-enum-shares

Using the Nmap script 'smb-enum-shares' lists the shares available and their read/write capabilities. tmp has anonymous access with read/write enabled, which indicates that users could view and edit the contents. IPC\$ also has anonymous access, which allows users to start an unauthenticated connection. The shares ADMIN\$, opt and print\$ do not allow anonymous access.

```
└─$ nmap -p 139,445 --script smb-enum-shares 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 18:49 +0100
Nmap scan report for 192.168.56.102
Host is up (0.0012s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Host script results:
| smb-enum-shares:
|   account_used: <blank>
|   \\192.168.56.102\ADMIN$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.102\IPC$:
|     Type: STYPE_IPC
|     Comment: IPC Service (metasploitable server (Samba 3.0.20-Debian))
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
|   \\192.168.56.102\opt:
|     Type: STYPE_DISKTREE
|     Comment:
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: <none>
|   \\192.168.56.102\print$:
|     Type: STYPE_DISKTREE
|     Comment: Printer Drivers
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\var\lib\samba\printers
|     Anonymous access: <none>
|   \\192.168.56.102\tmp:
|     Type: STYPE_DISKTREE
|     Comment: oh noes!
|     Users: 1
|     Max Users: <unlimited>
|     Path: C:\tmp
|     Anonymous access: READ/WRITE
└─
```

Enum4linux

Enum4linux is a command line tool used to enumerate Samba. Using the command `enum4linux -a` would enumerate the whole service: list shares, password policies, list users etc.

```
(inayat@kali)-[~]
$ enum4linux -a 192.168.56.102
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Sep 20 18:33:30 2026

===== ( Target Information ) =====
Target ..... 192.168.56.102
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

The known usernames in this service are:

- Administrator
- Guest
- Krbtgt
- Domain
- Admins
- Root
- Bin
- none

```
===== ( Session Check on 192.168.56.102 ) =====
[+] Server 192.168.56.102 allows sessions using username '', password ''
```

The lack of a username and password needed shows a null session can be made to the service. This is further reinforced by the ‘Session Check’ heading, which explains that the service allows users to log in with an empty username and password.

```
( Share Enumeration on 192.168.56.102 )

WORKGROUP METASPLOITABLE
Sharename Type Comment
print$ Disk Printer Drivers
tmp Disk oh noes!
opt Disk
IPC$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))
ADMIN$ IPC IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.

Server Comment
Workgroup Master
WORKGROUP METASPLOITABLE

[+] Attempting to map shares on 192.168.56.102
//192.168.56.102/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.56.102/tmp Mapping: OK Listing: OK Writing: N/A
//192.168.56.102/opt Mapping: DENIED Listing: N/A Writing: N/A
[E] Can't understand response:
NT_STATUS_NETWORK_ACCESS_DENIED listing \*
//192.168.56.102/IPC$ Mapping: N/A Listing: N/A Writing: N/A
//192.168.56.102/ADMIN$ Mapping: DENIED Listing: N/A Writing: N/A
```

After listing the shares available and the tool attempting to connect to the shares, mapping is denied on print\$, opt and ADMIN\$, with IPC\$ not giving a concrete result. However, mapping was enabled on tmp and listing can be performed. This allows users over a null session to view the contents stored in tmp.

```

===== ( Password Policy Information for 192.168.56.102 ) =====
Password:

[+] Attaching to 192.168.56.102 using a NULL share
[+] Trying protocol 139/SMB ...
[+] Found domain(s):
    [+] METASPLOITABLE
    [+] Builtin
[+] Password Info for Domain: METASPLOITABLE
    [+] Minimum password length: 5
    [+] Password history length: None
    [+] Maximum password age: Not Set
    [+] Password Complexity Flags: 000000
        [+] Domain Refuse Password Change: 0
        [+] Domain Password Store Cleartext: 0
        [+] Domain Password Lockout Admins: 0
        [+] Domain Password No Clear Change: 0
        [+] Domain Password No Anon Change: 0
        [+] Domain Password Complex: 0
    [+] Minimum password age: None
    [+] Reset Account Lockout Counter: 30 minutes
    [+] Locked Account Duration: 30 minutes
    [+] Account Lockout Threshold: None
    [+] Forced Log off Time: Not Set

[+] Retrieved partial password policy with rpcclient:

Password Complexity: Disabled
Minimum Password Length: 0

```

After inputting a blank password, the tool was able to list the password policy information for the SMB service on Metasploitable. This displays the information about the password requirements.

- Minimum password length set to '5' characters – Password length is very short
- Password history length set to 'None' – The system does not store old passwords to prevent users from reusing them again
- Maximum password age has not been set – There is no expiration date for when user passwords are expired to make users create a new one.
- Password complexity flags are set to '000000' – Passwords do not have requirements to include special characters, numbers, upper and lowercase letters etc. This means weak passwords are allowed by the service.
- Minimum password age is set to 'None' – Allows users to change passwords immediately.
- Account Lockout Threshold is set to 'None' – Allows users to make an unlimited amount of failed login attempts.

Below the 'Retrieved partial password policy with rpcclient' section states the minimum password length is set to '0', which differs from the previous statement of the minimum password length being '5'.

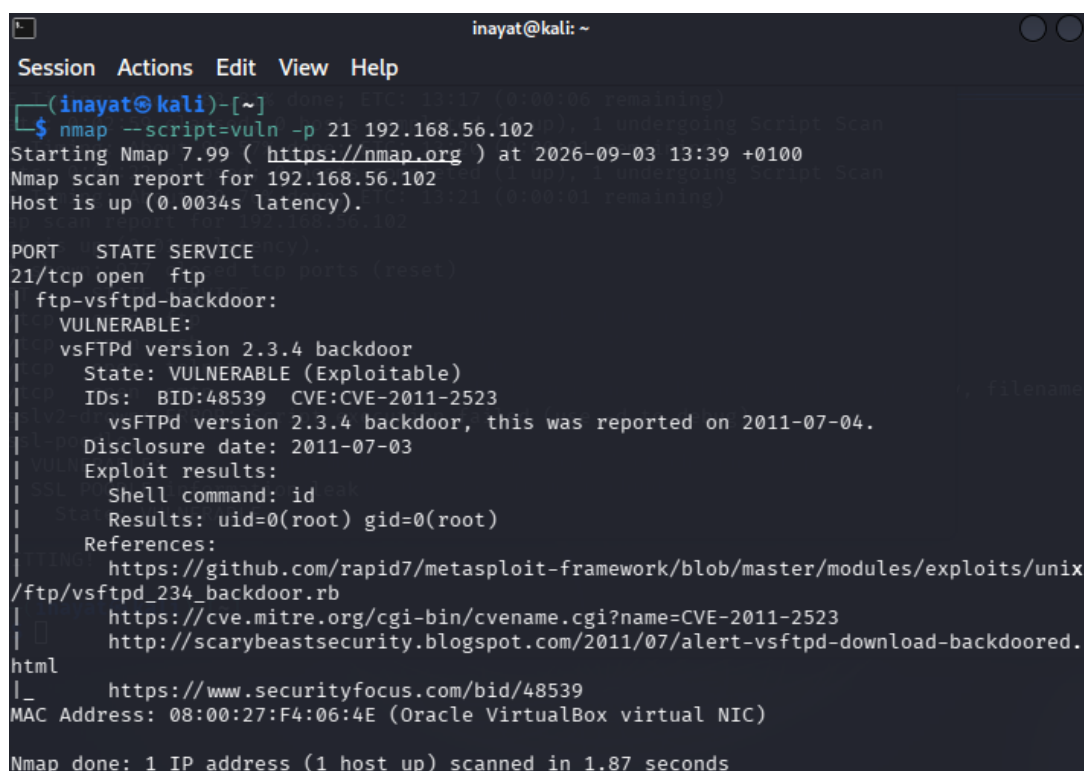
Vulnerability Assessment

Nmap's scripts can be used to discover specific known vulnerabilities of a service, which is done using '-script=vuln'.

Disclaimer – Vulnerability assessment has been analysed based on public information, utilising CVE records from sources such as the National Institute of Standards and Technology's (NIST) National Vulnerability Database (NVD) without executing exploits.

FTP – VsFTPD 2.3.4

vsFTPD is an obsolete version - Now unsupported, which makes it susceptible to exploitation.



```
inayat@kali: ~  
Session Actions Edit View Help  
(inayat@kali)-[~]  
$ nmap --script=vuln -p 21 192.168.56.102  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 13:39 +0100  
Nmap scan report for 192.168.56.102  
Host is up (0.0034s latency).  
  
PORT      STATE SERVICE  
21/tcp    open  ftp  
| ftp-vsftpd-backdoor:  
|   VULNERABLE:  
|     vsFTPD version 2.3.4 backdoor  
|     State: VULNERABLE (Exploitable)  
|     IDs:  BID:48539  CVE:CVE-2011-2523  
|     vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.  
|     Disclosure date: 2011-07-03  
|     Exploit results:  
|       Shell command: id  
|       Results: uid=0(root) gid=0(root)  
|     References:  
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd\_234\_backdoor.rb  
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523  
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html  
|       https://www.securityfocus.com/bid/48539  
|_    MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.87 seconds
```

Backdoor Command Execution

- CVE-2011-2523
- CVSS: 9.8 (CVSS version 3.x) – Critical, requires immediate attention
- Affected Versions: Downloaded on vsFTPD 2.3.4 between 30th June 2011-3rd July 2011
- Contains a backdoor exploitation which if triggered opens a hidden shell on port 6200
- Grants an unauthenticated user full control over the system with root privilege access

Possible Consequences

- Complete control over the system with root permissions to carry out further attacks
- Modification, deletion and corruption of files
- Data exfiltration of confidential organisation data
- Credential harvesting
- Installing and executing malware
- Lateral movement across a network to attack other machines

Mitigations

- Upgrade to the latest version of vsFTPD
- Switch to SFTP for encrypted file transfer
- Uninstall vsFTPd if it is unnecessary for your system

SSH – OpenSSH 4.7p1

- TOFU is a security risk for SSH. If an attacker positions themselves between the server and user (Man-in-the-Middle attack) before the initial connection has been made, they can present a malicious key to the client.
 - If accepted by the user, data is transmitted to the attacker.
- Software is outdated - Released in 2007 and is no longer supported.
 - This increases the likelihood of vulnerabilities and potential exploitation.

Username Enumeration

- CVE-2018-15473
- Affected versions: 2.3 – 7.7 (Version Applicable)
- CVSS: 5.3 (CVSS version 3.x) – Medium
- A flaw within OpenSSH causes the server to stop the process of authenticating inputted usernames.
- As there is no delay when processing usernames, opposed to a delay being in place should the user input valid or invalid credentials, attackers can send an abnormal packet to the server to enumerate for existing users by measuring the response time taken to authenticate users.

Possible Consequences

- Exposure of valid user accounts
- Brute-force attacks and password-guessing
- Future credential stuffing if user details are reused
- Likelihood of accounts being compromised, leading to data exfiltration and theft

Mitigations

- Implement strong authentication and credential principles
- Monitor for suspicious attempts to access accounts
- Upgrade to the latest version of OpenSSH

Telnet – Linux telnetd

```
(inayat@kali)-[~] open telnet
$ nmap --script telnet-encryption -p 23 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-03 12:13 +0100
Nmap scan report for 192.168.56.102 (1 host up) scanned in 8.23 seconds
Host is up (0.016s latency).
(quit) (inayat@kali)-[~]
PORT      STATE SERVICE
23/tcp    open  telnet
| telnet-encryption:
|_ Telnet server does not support encryption
MAC Address: 08:00:27:F4:06:4E (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.30 seconds
```

- The Telnet service by design sends data over plaintext, making it unencrypted and exposed to hackers who intercept the network traffic.
- Additionally, the server does not support encryption as seen in the image. The Nmap 'telnet-encryption' script explicitly states that the 'Telnet server does not support encryption'.
- Improper authentication methods as it only involves a username and password combination. Brute force attacks can be used to guess passwords to gain access to the server.
- When initiating a connection with the Telnet server, login credentials are shown to the user. Inputting the credentials gave access to the service.

[illegible]

Possible Consequences

- Data interception and exposure by malicious users
- Possible credential stuffing if users reuse username and passwords for external services
- Unauthorised access to the service to further advance attacks

Mitigations

- Replace Telnet with SSH
- Remove Telnet if remote access is unessential
- Enforce restrictions on who can access the Telnet server
- Modify the Telnet banner to remove the login credentials

SMTP – Postfix smtpd

- The service's responses to the usernames can be used to enumerate for valid user accounts on the host without authentication.
 - This flaw in the service leaves it open to username enumeration attacks to verify if an account exists on a system, leading to attackers compiling a list of accounts and using brute forcing techniques to gain access to them.

Man-in-the-Middle attack during Diffie-Hellman key exchange

```
└─$ nmap --script=vuln -p 25 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-04 13:32 +0100
Nmap scan report for 192.168.56.102
Host is up (0.015s latency).

PORT      STATE SERVICE
25/tcp    open  smtp
|_sslv2-drown: ERROR: Script execution failed (use -d to debug)
|_ssl-dh-params:
|_VULNERABLE:
|_   Anonymous Diffie-Hellman Key Exchange MitM Vulnerability
|_   State: VULNERABLE
|_   Transport Layer Security (TLS) services that use anonymous
|_   Diffie-Hellman key exchange only provide protection against passive
|_   eavesdropping, and are vulnerable to active man-in-the-middle attacks
|_   which could completely compromise the confidentiality and integrity
|_   of any data exchanged over the resulting session.
|_   Check results:
|_   ANONYMOUS DH GROUP 1
|_   Cipher Suite: TLS_DH_anon_WITH_AES_128_CBC_SHA
|_   Modulus Type: Safe prime
|_   Modulus Source: postfix builtin
|_   Modulus Length: 1024
|_   Generator Length: 8
|_   Public Key Length: 1024
|_   References:
|_   https://www.ietf.org/rfc/rfc2246.txt
```

- The Diffie-Hellman (DH) key exchange is an algorithm which allows to users to create a shared private key over an insecure public network without exposing the private key itself.
- Despite the confidentiality provided by the DH key exchange, it does not prevent Man-in-the-Middle (MitM) attacks. An attacker can intercept the exchanged public keys and replace those keys with their own malicious keys.
- This allows attackers to intercept the and rewrite emails between the client and the mail server.

Mitigations

- **Public Key Infrastructure (PKI)** – Users can possess two unique keys, a public key to lock and encrypt messages and a private key to unlock and decrypt messages.

- Use digital signatures to verify the sender's identity when sharing messages.

Logjam vulnerability

```

Transport Layer Security (TLS) Protocol DHE_EXPORT Ciphers Downgrade MitM (Logjam)
State: VULNERABLE
IDs: CVE:CVE-2015-4000 BID:74733
The Transport Layer Security (TLS) protocol contains a flaw that is
triggered when handling Diffie-Hellman key exchanges defined with
the DHE_EXPORT cipher. This may allow a man-in-the-middle attacker
to downgrade the security of a TLS session to 512-bit export-grade
cryptography, which is significantly weaker, allowing the attacker
to more easily break the encryption and monitor or tamper with
the encrypted stream.
Disclosure date: 2015-5-19
Check results:
EXPORT-GRADE DH GROUP 1
Cipher Suite: TLS_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA
Modulus Type: Safe prime
Modulus Source: Unknown/Custom-generated
Modulus Length: 512
Generator Length: 8
Public Key Length: 512
References:
https://weakdh.org
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-4000
https://www.securityfocus.com/bid/74733

```

- CVE-2015-4000
- CVSS: 3.7 (CVSS version 3.x) - Low
- A flaw in the Transport Layer Security (TLS) protocol allows an ongoing MitM attacker to stealthily downgrade the TLS session to weak 512-bit export-grade cryptography.

Potential consequences

This allows attackers to intercept and decrypt the data, which could lead to modifying the data during the information exchange.

Mitigations

- Disable the weak 512-bit DH key ciphers and replace it with the modern version, Elliptic Curve Diffie-Hellman (ECDH)
- Completely disable the DHE_EXPORT cipher suites.

DNS – ISC BIND 9.4.2

BIND 9.4.2 has reached End-of-Life (EOL) and has been unsupported since 2012 with modern renditions of BIND replacing the obsolete version.

DNS Insufficient Socket Entropy Vulnerability/Kaminsky bug

- CVE-2008-1447
- Affected versions: 9.4.1 < 9.4.2 (Version Applicable)
- CVSS: 6.8 (CVSS version 3.x) - Medium
- A DNS cache poisoning attack which exploited the service not randomising DNS transaction IDs and Source UDP ports adequately. This allows attackers to input malicious DNS responses into the DNS resolver's cache, redirecting users to the attacker's determined destination.

Possible Consequences

- Users are sent to websites hosted by an attacker, leading to further attacks such as theft
- Malware injection into user's devices
- Attackers can manipulate users into entering their credentials and personal information, leading to identity fraud, credential stuffing and theft of money.
- Can generate reputational damage for websites which the DNS server was initially meant to redirect users to.

Mitigations

- Update to the latest version of BIND which contains stronger security architecture, regular updates and patches
- Apply Domain Name System Security Extensions (DNSSEC)
- Use a secure DNS resolver
- Use DNS over HTTPS (DoH) to encrypt DNS lookups

Buffer Overflow attack

- CVE-2008-0122
- Affected versions: 9.4.2 (Version Applicable)
- CVSS: 10 (CVSS version 2.0) - Severe
- The attack is caused by an off-by-one error in the inet_network function within libbind

Possible Consequences

- Allows attackers to execute DoS attacks

- Possibility to perform remote code execution and install arbitrary code to corrupt the server's memory

Mitigations

- Upgrade to the modern version of BIND and regularly update and patch the software
- Use Address Space Layout Randomisation (ASLR) to randomly move address spaces where code resides so attackers cannot identify executable code.
- Implement Data Execution Prevention (DEP) to flag memory regions as non-executable to disallow attackers from running injected shellcode.

HTTP – Apache 2.2.8

Apache 2.2.8 has reached its End-of-Life and is now unsupported. The latest version is Apache 2.4.x as of 18/09/2026.

```
(inayat@kali)-[~]
$ nmap -script=vuln -p 80 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-20 15:26 +0100
Stats: 0:02:07 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.37% done; ETC: 15:28 (0:00:03 remaining)
Stats: 0:04:12 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.37% done; ETC: 15:30 (0:00:07 remaining)
Nmap scan report for 192.168.56.102
Host is up (0.0064s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_http-trace: TRACE is enabled
|_http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|   State: LIKELY VULNERABLE
|   IDs: CVE:CVE-2007-6750
|   Box_C Slowloris tries to keep many connections to the target web server open and hold
|   them open as long as possible. It accomplishes this by opening connections to
|   the target web server and sending a partial request. By doing so, it starves
|   the http server's resources causing Denial Of Service.
|
|   Disclosure date: 2009-09-17
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|   http://ha.ckers.org/slowloris/
```

Slowloris DoS Attack

- CVE-2007-6750
- Affected versions: 1.x and 2.x – 2.2.14
- CVSS: 5.0 (CVSS version 2.0) - Medium
- Exhausts the HTTP server by keeping multiple connections open by sending partial requests

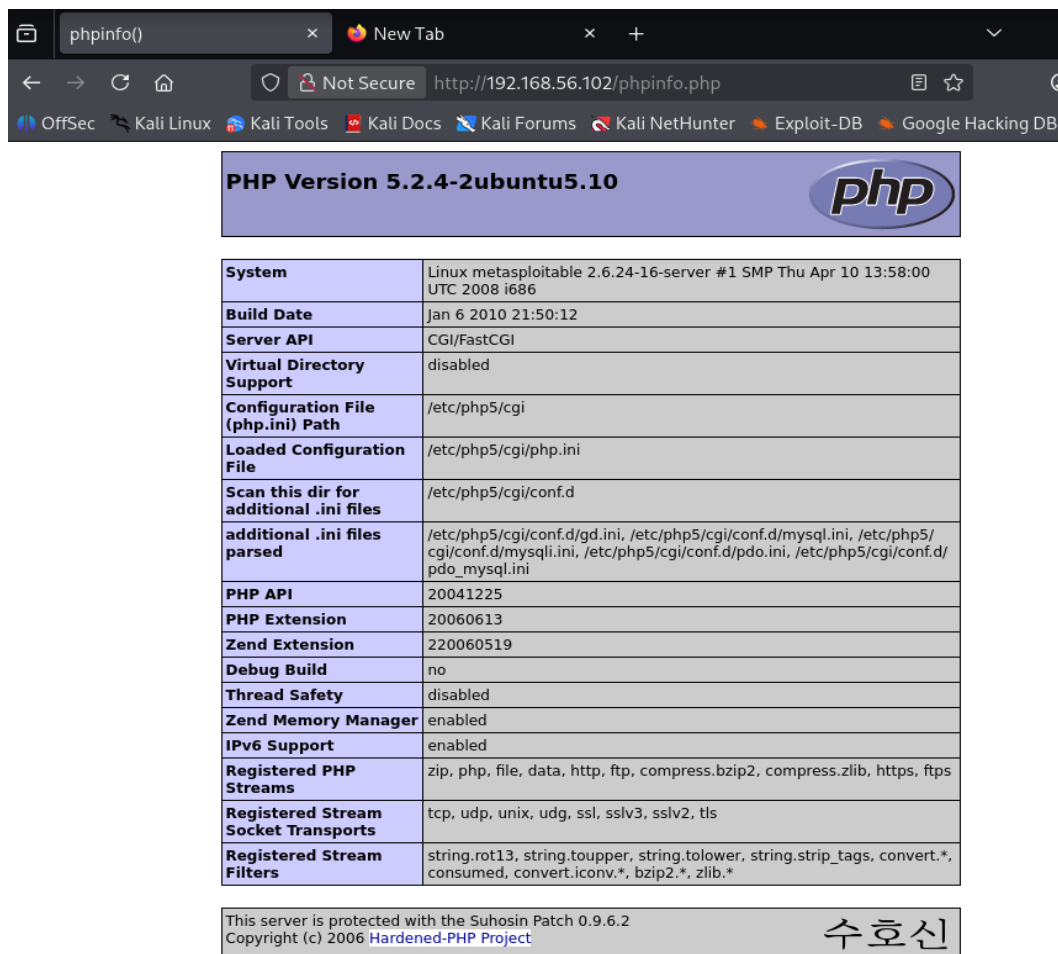
Potential Consequences

- Legitimate users are unable to visit the website as connections are timed out
- Server resources are exhausted
- Operational downtime as IT teams have to remediate the server which would hinder business operations leading to financial loss if clients are unable to access their website.

Mitigations

- Implement a Web Application Firewall (WAF) to monitor and block malicious traffic from entering the web server.

- Setup a Content Delivery Network (CDN) to distribute user network traffic to local cached servers to speed up web content delivery. If a DoS attack occurred, the CDN would redirect users to another geographical server.
- Use rate limiting to limit the amount of requests a single user can make to the server to reduce the volume of traffic being sent.



PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream Socket Transports	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls
Registered Stream Filters	string.rot13, string.toupper, string.tolower, string.strip_tags, convert.*, consumed, convert.iconv.*, bzip2.*, zlib.*

This server is protected with the Suhosin Patch 0.9.6.2
Copyright (c) 2006 Hardened-PHP Project

- ‘phpinfo.php’ is exposed and accessible to the public, containing sensitive information which can be exploited as attackers assess for vulnerabilities based on the PHP version, server configurations and security settings it contains.
- PHP version 5.2.4 is an outdated version for the scripting language.

Directory Traversal vulnerability

- CVE-2007-4825
- Affected versions: PHP 5.2.4 and earlier (Version Applicable)
- CVSS: 7.5 (CVSS version 2.0) - High
- Attackers can bypass open_basedir security restrictions using the dl() function

- The dl() function didn't properly validate its input paths, so attackers can use '..' to traverse outside the restricted directory made by the open_basedir setting to direct the dl function to load a malicious library.

Possible Consequences

- Executing arbitrary code
- Exposing sensitive information such as configuration files and database credentials
- Exfiltration and corruption of data

Mitigations

- Update to the latest version of PHP
- Disable the dl() function completely

Cross Site Tracing (XST)

- TRACE method enabled according to Nikto which could lead to Cross Site Tracing (XST) attacks.
- TRACE is a method which repeats the exact request back to the client from the web server.
- XST works in conjunction with Cross Site Scripting (XSS) and the TRACE method, where the attacker can exploit the TRACE method to obtain sensitive information such as session cookies to impersonate a user on the web server.
- Despite the 'HttpOnly' flag on cookies being used to protect a user's session details from being exposed, using TRACE will echo these details on the header.

```
(inayat@kali)-[~]
$ nikto -h http://192.168.56.102/
- Nikto v2.6.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-17 18:30:27 (GMT1)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ ERROR: Failed to check for updates:
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).

+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross\_Site\_Tracing

+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via a HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via
```

Potential Consequences

- Session hijacking as attackers are able to capture session data and tokens to impersonate a victim, gaining access to their accounts
- Further attacks such as XSS to exploit web applications and user actions
- Exposure of credentials, passwords and sensitive user information

Mitigations

- Disable the TRACE method within the web server.
- Only allow the specific methods required by your application
- Implement a Web Application Firewall (WAF) to prevent malicious traffic attempting to enter the web server
- Apply the Content-Security-Policy security header to restrict XSS script execution

SMB – Samba smbd 3.0.20-Debian

- Message_signing: disabled (dangerous, but default) – Messages between the client and server are not signed. This removes the integrity and authentication behind the message as the identity of the sender cannot be verified without a signing.
 - Facilitates MitM attacks which can result in impersonation of users on a network, interception of data and remote code execution.
 - Message signing should be enabled as a precaution.
- Tmp share has a comment labelled 'oh noes!' - Could be an indicator to unauthorised users that sensitive information may be stored on that share.
 - Share names and their comments should avoid explicitly and implicitly mentioning sensitive content
- Anonymous logins (null session logins) are enabled – unauthenticated users can view and potentially write to the contents stored, specifically towards the tmp share.
 - Could lead to data exposure, exfiltration and modification of data.
 - The ability to allow anonymous login should be disabled.
- Password policy is exposed to users on the service. The policy itself is weak: minimum length of 5 characters, lack of complexity and unlimited login attempts.
 - These weak principles heighten the possibility of brute force attacks.
 - The password policy must be amended to increase the complexity and strengthen the security of passwords.

Remote Command Injection Vulnerability

- CVE-2007-2447
- Affected versions: 3.0.0 – 3.0.25rc3 (version applicable)
- CVSS: 6.0 (CVSS version 2.0) - Medium
- Using the enabled 'username map script' configuration option, an attacker can pass unfiltered inputs by creating a username containing shell meta characters to execute arbitrary commands

Potential Consequences

- Root access to the server to supplement attacks such as credential harvesting, malware execution and attacking other hosts on the network.
- Installation of a backdoor for stealth, persistent access
- Data exfiltration from shares and potentially corruption of files
- Denial of Service attacks which exhaust server resources.

Mitigations

- Upgrade to the latest version of Samba
- Disable username map script in the smb.conf configuration file
- Include firewall rules that restrict access to ports 139 and 445 from unauthenticated networks attempting to access the network.

Conclusion

The overall objective was to simulate a risk analysis exercise on a vulnerable system through reconnaissance and enumeration, to demonstrate the process auditors may follow to analyse technological systems, detecting vulnerabilities on their services and what organisations should do moving forward to better strengthen their systems. This project serves to inform individuals, CEOs and overall organisations about the risks associated with irregular monitoring, updating and assessment of IT systems and it places a significant importance towards maintaining them. From an organisational perspective, regularly improving and monitoring technology is paramount for optimal business growth and operations, as from the services enumerated show that the vulnerabilities presented can lead to critical consequences such as exposure of data on their services, leading to operational downtime as cyber security teams work to resolve the problem.

The project was done utilising Nmap against Metasploitable 2, an intentionally vulnerable host. Nmap was used for reconnaissance by detecting the IP address of Metasploitable, the OS version and the ports and services that are open on the host alongside their specific service versions. A total of 23 ports are open with 7 services selected to enumerate in this project in depth, analysing services using a variety of tools beyond Nmap scripts, such as Nikto for HTTP, netcat to open TCP connections to SMTP, Enum4linux and smbclient to enumerate the SMB service. These tools worked collectively to investigate services, assessing for how they were configured and how they worked.

Throughout the enumeration phase, a range of vulnerabilities have been identified across these services. Vulnerability assessment looked at weaknesses with the service itself and how a service has been misconfigured. Additionally, specifically named vulnerabilities have been identified on services, ranging from low to severe according to their CVSS scores. These vulnerabilities have been researched using Nmap NSE scripts and online sources such as NIST's NVD. A severe vulnerability identified is FTP's version, vsftpd 2.3.4, which contains a backdoor vulnerability that provides the threat actor with full control over the system with root privileges to cause harm. This vulnerability has a CVSS rating of 9.8, meaning this vulnerability requires immediate resolution as it has extreme consequences if left unattended. Following their assessment, remediation strategies were considered and written for each service which organisations should consider taking to prevent exploitation of their systems and reinforce their security.

Despite the wide scope of reconning and enumerating a host system, there were a few limitations of this project. The most notable limitation was that no exploitations were made towards the services to assess the nature of how vulnerable they are to an organisation. The project applied the PTES's framework which only incorporated for

intelligence gathering, vulnerability analysis and reporting, with exploitation being excluded. Vulnerability research was conducted based on public documentation of Metasploitable itself and the vulnerabilities that were documented on sources such as Exploit Database and the NVD. This problem could have been mitigated by changing the scope of the project to incorporate exploitation towards the services to test how detrimental exploits are in real time. The decision to not exploit the system's vulnerabilities was made from the perspective of a cyber security risk analyst opposed to a dedicated red teamer, where they do not have authorisation to exploit systems. Exploiting each service would have increased the length and complexity of this project as services such as HTTP contained a variety of exploits to utilise.

Another limitation for this project was this was conducted exclusively on Kali Linux without directly interacting with the Metasploitable machine. This was a limitation as no further inspection could be made towards the target machine to investigate hidden files, server policies, the full extent of server configuration settings and the security controls that are already present. Enumeration of these services was performed independently by identifying the service and then supplementing the discoveries through research. The vulnerabilities discovered were based on public documentation surrounding specific exploits and inference without examining the machine itself for confirmed findings. Despite using an already documented vulnerable machine like Metasploitable where information about the machine is already available, an enterprise machine will have limited details surrounding user information, OS versions and security controls already present without prior knowledge. Black box reconnaissance and enumeration involves investigating a system without prior context, making it difficult to thoroughly analyse for hidden vulnerabilities with the increased chance to generate false positives and negatives. An alternative approach could have been to have consulted the already available Metasploitable documentation to have assisted the analysis of the machine's services, files and configurations and to have directly accessed the machine to uncover its details.

The work performed in this project was for educational and informational purposes only and should not serve as a comprehensive guide to enumerate a host and its contents. The project was conducted within an isolated virtual environment, analysing an intentionally vulnerable virtual machine for which permission was granted to use. Do not intercept network traffic of a public network. Do not expose the machines you are investigating to an external network to prevent external users from accessing and intercepting its network traffic. Do not examine a system you have no explicit permission to use. Seek authorisation from the relevant parties before conducting a cyber security analysis.

Use of AI

Using Claude as the chosen AI assistant, AI was used during my project to proofread my documentation, brainstorm ideas regarding to the writeup and structure of the document, troubleshooting problems during virtual machine setup and analysis of services, ensuring the independent decisions taken when building the project remain consistent in writing, and fact check technical and writing accuracies and then following through by researching the output further using external resources such as Google and NVD. All scanning, enumeration, writing, decision making, research and analysis were performed single-handedly. The multiple options AI has presented during the project were considered, the final decision was purely independent through thorough deliberation.

References

National Institute of Standards and Technology (NIST) National Vulnerability Database (NVD). CVE-2011-2523 <https://nvd.nist.gov/vuln/detail/cve-2011-2523>

Red Hat. CVE-2011-2523. <https://access.redhat.com/security/cve/cve-2011-2523>

NIST NVD. CVE-2018-15473. <https://nvd.nist.gov/vuln/detail/cve-2018-15473>

NIST NVD. CVE-2015-4000. <https://nvd.nist.gov/vuln/detail/cve-2015-4000>

NIST NVD. CVE-2008-1447. <https://nvd.nist.gov/vuln/detail/cve-2008-1447>

NIST NVD. CVE-2008-0122. <https://nvd.nist.gov/vuln/detail/cve-2008-0122>

NIST NVD. CVE-2007-6750. <https://nvd.nist.gov/vuln/detail/cve-2007-6750>

NIST NVD. CVE-2007-4825. <https://nvd.nist.gov/vuln/detail/cve-2007-4825>

NIST NVD. CVE-2007-2447. <https://nvd.nist.gov/vuln/detail/cve-2007-2447>